Agent B/E 연동 명세

2026-10-21 · 현재 Gateway 구현 기준. B/E 담당자에게 이 문서와 docs/openapi/python-internal-api.yaml을 함께 전달합니다. 실제 내부망 연동 완료를 의미하지 않습니다.

1. 연결 구조와 책임

FE → Gateway → Agent B/E → 대화 이력·업무 실행
↓ 추가 인증이 필요한 경우
Gateway /internal/v1/auth/operations → 세션 서비스·PFC

주체	책임
Gateway	세션·채널 접근 인증, 로그인 전환, PFC 추가 인증 검증, HTTP/SSE 전달
Agent B/E	thread 소유권, 게스트 대화 연결, 대화 이력, 업무별 인증 요구·등록 매핑, 실제 실행·중복 방지
세션 서비스	세션·인증 문맥·등록·소비 영수증 보관, 원자 변경 및 장애 전환

Gateway는 MVC/Tomcat이며 RestClient로 B/E에 요청합니다. 발화·도구의 SSE 응답은 SseEmitter로 전달합니다. B/E는 Gateway 세션 저장소를 직접 조회하거나 FE 쿠키를 받지 않습니다.

2. Gateway → B/E 경로

FE 경로	B/E가 구현할 경로	메서드
/api/chat	/internal/v1/chat	POST
/api/chat/threads/{threadId}/tools/{tool}	/internal/v1/chat/threads/{threadId}/tools/{tool}	POST
/api/chat/threads	/internal/v1/chat/threads	GET
/api/chat/threads/{threadId}/messages	/internal/v1/chat/threads/{threadId}/messages	GET
/api/chat/threads/{threadId}/artifacts/{artifactId}	/internal/v1/chat/threads/{threadId}/artifacts/{artifactId}	GET

query는 원문 전달합니다. 발화는 문자열 threadId를 포함한 JSON이며 최대 1MiB입니다. 그 외 발화 필드는 B/E가 정의하며 Gateway는 추가·재직렬화하지 않습니다. 도구 본문은 원래 Content-Type과 바이트를 전달합니다. threadId는 현재 세션과 일치해야 합니다.

Gateway 인스턴스는 하나이며 인증된 세션의 channelId로 목적지를 선택합니다. staging 채널은 chat.staging.channels의 주소, 나머지는 chat.backend.base-url입니다. staging은 허용 목록의 회원만 접근합니다. Agent B/E 호출은 현재 Eureka가 아닌 설정 URL을 사용합니다.

자동완성은 별도 search-autocomplete-service, 클릭은 Gateway 자체 로그로 처리하므로 Agent B/E에 전달되지 않습니다.

3. B/E가 받는 헤더

헤더	규칙
Authorization	Bearer 서비스 인증값. Gateway의 BACKEND_SERVICE_CREDENTIAL과 B/E 검증값을 일치시킴
X-Authenticated-User-Id	회원 PID 또는 게스트 식별자. 사용자 입력을 신원으로 사용하지 않음
X-Authenticated-User-Type	MEMBER 또는 GUEST
X-Authenticated-Channel-Id	세션에서 검증한 채널
X-Authenticated-Guest-Id	게스트의 현재 식별자 또는 로그인 전 게스트 식별자. 처음부터 회원이면 생략
X-Auth-Context	회원이며 thread가 있는 요청에 발급. 기본 10분 유효. 추가 인증 등록에만 사용
X-Verified-Auth-Requests	resume 검증 성공 시 authReqId를 쉼표로 구분. 예: ar_1, ar_2. 없으면 인증 완료로 간주하지 않음
Idempotency-Key	발화·도구 요청의 FE 요청 키. 실제 업무 중복 방지는 B/E가 구현
X-Request-Id	추적 식별자. 사용자 인증 수단이 아님

외부 Authorization·Cookie·X-Mfa-Result·X-Requested-Login 및 위조 신원 헤더는 제거됩니다. B/E는 서비스 인증을 먼저 검사하고, 접근 경로를 Gateway로 제한해야 합니다. 헤더가 존재하는 것만으로 신뢰하면 안 됩니다. 서비스 토큰·인증 문맥·PID·고객 대조값은 로그에 남기지 않습니다. 서비스 토큰과 X-Auth-Context를 FE 응답에 포함하지 않습니다.

4. 요청·응답 예시 및 SSE

POST /internal/v1/chat
Authorization: Bearer 〈GW_TO_BE_SECRET〉
Content-Type: application/json
X-Authenticated-User-Id: 〈PID〉
X-Authenticated-User-Type: MEMBER
X-Authenticated-Channel-Id: 〈CHANNEL_ID〉
X-Auth-Context: 〈OPAQUE_CONTEXT〉
Idempotency-Key: 〈REQUEST_KEY〉

{"threadId":"thread-1","text":"한도 안내"}

text는 설명용 예시이며 확정된 B/E 필드명이 아닙니다. 실제 발화·도구 payload와 이벤트 이름은 FE/B/E가 합의해야 합니다.

HTTP/1.1 200 OK
Content-Type: text/event-stream

: heartbeat

event: message
data: {"text":"안녕하세요"}

항목	규칙
시작	Gateway의 인증·MFA 처리 성공 후 B/E 호출. 정상 SSE는 200과 text/event-stream 사용
형식	이벤트 끝에 빈 줄. data/event/id/retry/주석/여러 줄·UTF-8을 Gateway가 재작성하지 않음
heartbeat	기본 읽기 간격 제한 30초보다 짧게 전송. 예: 15초마다 주석 이벤트. 첫 데이터 대기에도 제한 적용
버퍼링	B/E 및 앞단 프록시가 이벤트마다 flush하고 전체 응답을 모으지 않아야 함
종료	B/E 응답 EOF에서 종료. 특정 final 이벤트 이름만으로 Gateway가 종료하지 않음
세션 만료	시작된 응답은 자연 만료만으로 중단하지 않음. SSE 수신·heartbeat는 세션 활동 연장 아님
오류	시작 전 B/E HTTP 상태·본문은 그대로 전달. 시작 후 HTTP 코드는 변경할 수 없으며 중계 오류를 정상 완료로 해석하지 않음
재시도	Gateway는 B/E 호출을 자동 재시도하거나 redirect를 따라가지 않음. FE 재시도에도 B/E가 중복 실행을 차단

일반 JSON·바이너리 응답도 상태·본문을 전달합니다. 연결 전용 헤더는 제거하며 인증 만료 헤더는 Gateway가 관리합니다. GET에는 세션 연장과 홈페이지 _I 발급이 없습니다.

5. 게스트 → 회원 전환과 새 대화

FE가 같은 threadId의 POST /api/chat에 X-Requested-Login: true와 플랫폼 _O 쿠키를 보내면 Gateway가 PFC 검증 후 세션을 회원으로 교체합니다. B/E는 바뀐 회원 PID와 이전 X-Authenticated-Guest-Id로 기존 대화 연결 여부를 판단합니다. 별도 대화 이전 API는 호출하지 않습니다.

새 대화는 FE의 POST /api/auth/session/restart입니다. 유효한 회원 신원은 유지하고 세션 ID·threadId를 교체합니다. B/E는 새로운 thread를 생성하며 이전 업무 인증을 승계하지 않습니다. 쿠키가 유실된 회원의 기존 thread 재접속은 재인증 후 B/E 소유권 확인이 필요하고, 게스트는 새 대화로 처리합니다.

6. B/E → Gateway 추가 인증 등록

POST /internal/v1/auth/operations. B/E는 Gateway가 전달한 X-Auth-Context와 별도 서비스 Bearer를 보냅니다. 이 방향의 인증값은 GATEWAY_SERVICE_CREDENTIAL이며 GW→B/E 토큰과 구분합니다. FE가 직접 호출하는 API가 아닙니다.

JSON 필드	조건
key	필수. 동일 등록 재시도는 같은 key, 한 업무의 별도 인증은 서로 다른 key
operationId, version, interfaceId	필수. 각 1~128자, 영문·숫자·점·밑줄·콜론·하이픈. interfaceId는 Gateway 허용 목록에 등록
actionHash	필수. 43자 base64url. 실제 업무 내용과 연결해 B/E가 생성·보관. 해시 원문 정규화 규칙은 B/E가 확정
ssn, iPin	하나 이상 필수. 값이 있으면 공백 불가, 최대 2048자. 실제 보호·암호화 형식은 PFC 계약 확인 필요
code, usage, content	모두 필수, 공백 불가, 각 최대 2048자. 실제 플랫폼 대조값

key도 위 식별자 규칙을 적용합니다. 고객·채널·thread는 body로 받지 않고 인증 문맥에서 결정합니다.

{"authReqId":"ar_...","sdkInput":"〈PFC_SDK_INPUT〉","expiresAt":1792550000000}

성공 200. expiresAt은 UTC epoch milliseconds입니다. 같은 회원·채널·thread·업무 범위에서 같은 key와 내용이면 동일 결과, 내용 변경이면 409입니다. 등록 기한은 기본 10분이며 재시도로 연장하지 않습니다. sdkInput은 FE SDK에 전달하고 고객 대조값은 FE에 반환하지 않습니다.

등록 오류는 400 INVALID_ARGUMENT(형식), 401 UNAUTHENTICATED(문맥 형식 등), 403 PERMISSION_DENIED 또는 MFA 관련 상태(서비스 토큰 불일치·권한·만료), 409 CONFLICT(키 충돌), 503 UNAVAILABLE(연동 장애) 등을 반환합니다. 의존 서비스 오류는 내부 API에서 502 등으로 나타날 수 있습니다. 공통 본문은 {error:{code,status,message}}이며 message는 빈 문자열입니다. 모든 오류를 동일한 업무 재실행으로 처리하지 않습니다.

7. 인증 결과 재개와 B/E 실행 조건

1. B/E: 업무에 필요한 인증별로 등록하고 authReqId·업무 버전·actionHash 매핑 보관
2. B/E → FE: authReqId·sdkInput·expiresAt 전달 (전달 이벤트 형식은 FE/B/E 합의)
3. FE: SDK 인증 후 결과 JSON 배열을 padding 없는 base64url로 인코딩
4. FE → GW: 같은 thread의 POST /api/chat + X-Mfa-Result + Idempotency-Key
5. GW: 전체 검증·원자 소비 후 B/E에 X-Verified-Auth-Requests 전달
6. B/E: 필요한 ID 전부, 고객·thread·업무 버전·내용 일치 확인 후 중복 없이 실행

디코딩된 FE 헤더 예: `[{"authReqId":"ar_1","tranID":"T001","txId":"X001","method":"FINANCE_CA"}]`. 기본 최대 8건·헤더 4096자입니다. B/E에는 이 원문 대신 검증된 ID 목록만 전달됩니다.

Gateway가 인증 결과를 검증해도 B/E의 현재 업무 내용까지 판단하지는 않습니다. 등록 후 업무 내용이 바뀌면 B/E가 이전 인증으로 실행하지 않아야 합니다. 실패는 SSE 시작 전에 반환하며 B/E를 호출하지 않습니다. 일괄 소비는 세션 서비스의 책임이고 실제 업무 실행 멱등성은 B/E의 책임입니다.

전달 실패 후 동일 키·본문·목적지·인증 목록 재시도는 유효한 소비 영수증으로 다시 전달될 수 있습니다. 따라서 B/E가 업무 식별자 기준 중복 실행을 막아야 합니다. 인증 결과 재사용 기한은 기본 2분과 플랫폼 기한 중 짧은 값이며, 현재 전달 헤더에는 이 기한이 포함되지 않습니다. 실제 업무 적용 시점의 인증 기한 검사 방식은 추가 합의 대상입니다.

8. 연동 완료 기준과 미확정 사항

확인 항목	완료 조건
일반 호출	위 5개 경로·query·본문·상태 코드 및 신뢰 헤더 검증
대화 연결	게스트, 로그인 전환, 새 대화, 다른 고객 thread 접근 차단
SSE	첫 이벤트 즉시 수신, heartbeat, 긴 응답, 연결 종료·timeout, 오류 후 중복 실행 방지
MFA	단일·복수 등록, 일부 실패 시 실행 금지, ID 누락·업무 변경 거절, 동일 요청 재전달 중복 방지
채널	staging 게스트 거절·허용 회원만 접근·올바른 환경으로 라우팅
실제 연동	PFC 구현, SDK 보호 형식, 비소비 검증 가능 여부, 세션 서비스 원자성·장애 전환 검증

발화·도구 body, SSE 업무 이벤트, actionHash 정규화, 인증 결과의 실제 적용 시점 기한 검사는 상대 서비스와 확정해야 합니다. 현재 Gateway 자동화 테스트 통과는 이 외부 구현의 완료를 보장하지 않습니다. offline 프로필은 메모리 세션·PFC mock을 사용하며, 내부망 프로필의 PFC 미구현 상태에서는 503으로 차단합니다.